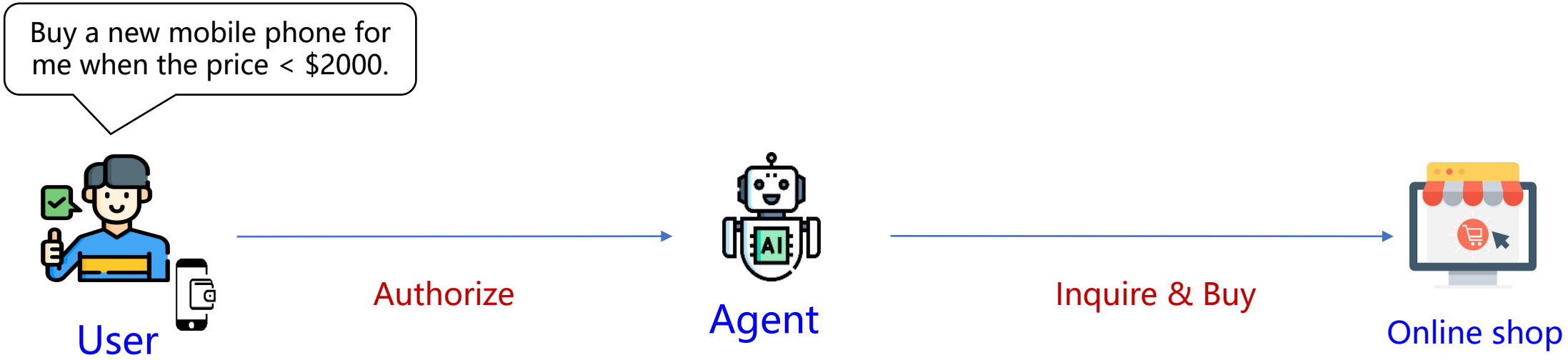
How to Authorize your AI Agent ?

Cheng-Kang Chu, Huawei

AI Agent Authorization by Users



Considerations…

- **Pre-authorization:** The agent can work 24/7, but not human
- **Task Scope Precision:** The permission must be strictly confined to the exact task
- **Budget Privacy:** The agent proves sufficient authorization without revealing our budget
- **Theft Prevention:** The credential must be cryptographically bound to the agent
- **Dispute Accountability:** There must be an undeniable, cryptographically signed record

Authorizing Your AI Agent: The Indirect OAuth Method

Advantages (Pros):

- **Universal Adoption:** Industry standard, supported by almost all SaaS APIs
- **Evolving Security:** Modern extensions (like DPoP) bind tokens to specific clients
- **Granular Capable:** Extensions like RAR allow for fine-grained access conditions
- **Centralized Revocation:** Easy to kill access from a single dashboard.

Disadvantages (Cons):

- **Centralized tracking:** Central servers track every action the AI takes
- **Human-in-the-Loop:** Requires manual browser clicks, blocking true AI autonomy
- **Lack of Privacy:** Fine-grained permissions are exposed in plaintext to the resource server

Direct User-to-Agent Authorization: The Verifiable Credential Paradigm

Advantages (Pros):

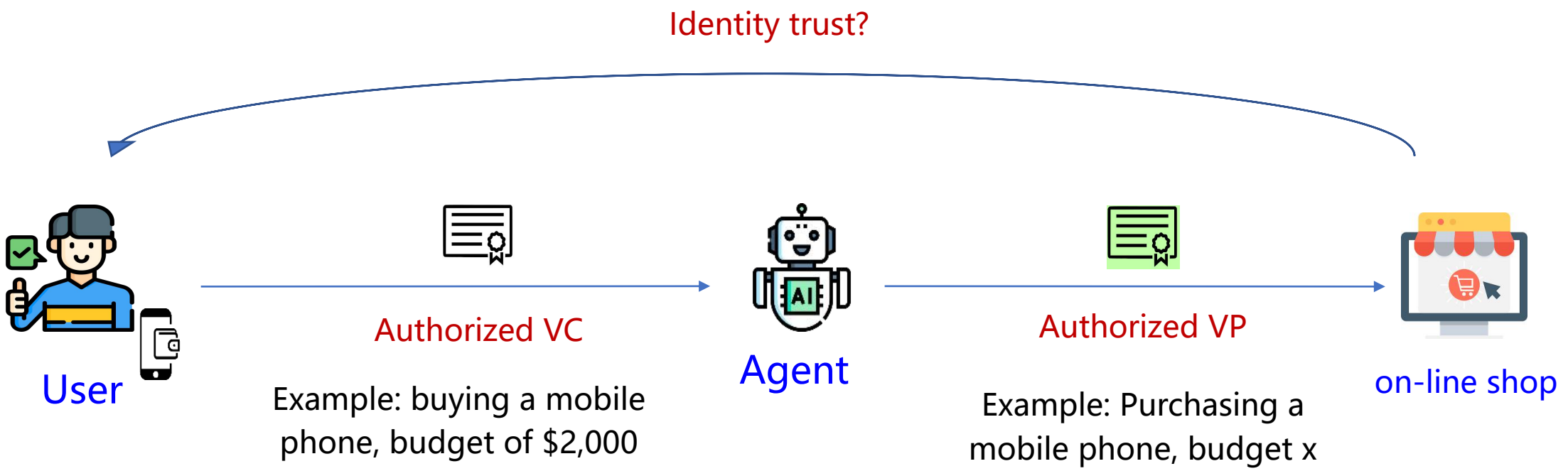
- **Fully Autonomous:** credentials are self-contained. The Agent doesn't need to constantly ping a server to exchange tokens or interrupt workflows for human browser redirects
- **Privacy-Preserving:** Uses Zero-Knowledge Proofs (ZKP) to hide sensitive limits
- **Cryptographic Accountability:** Uses VP to create an undeniable, cryptographically signed audit trail for liability disputes

Disadvantages (Cons):

- **Immature Ecosystem:** most modern external APIs do not yet know how to verify VCs

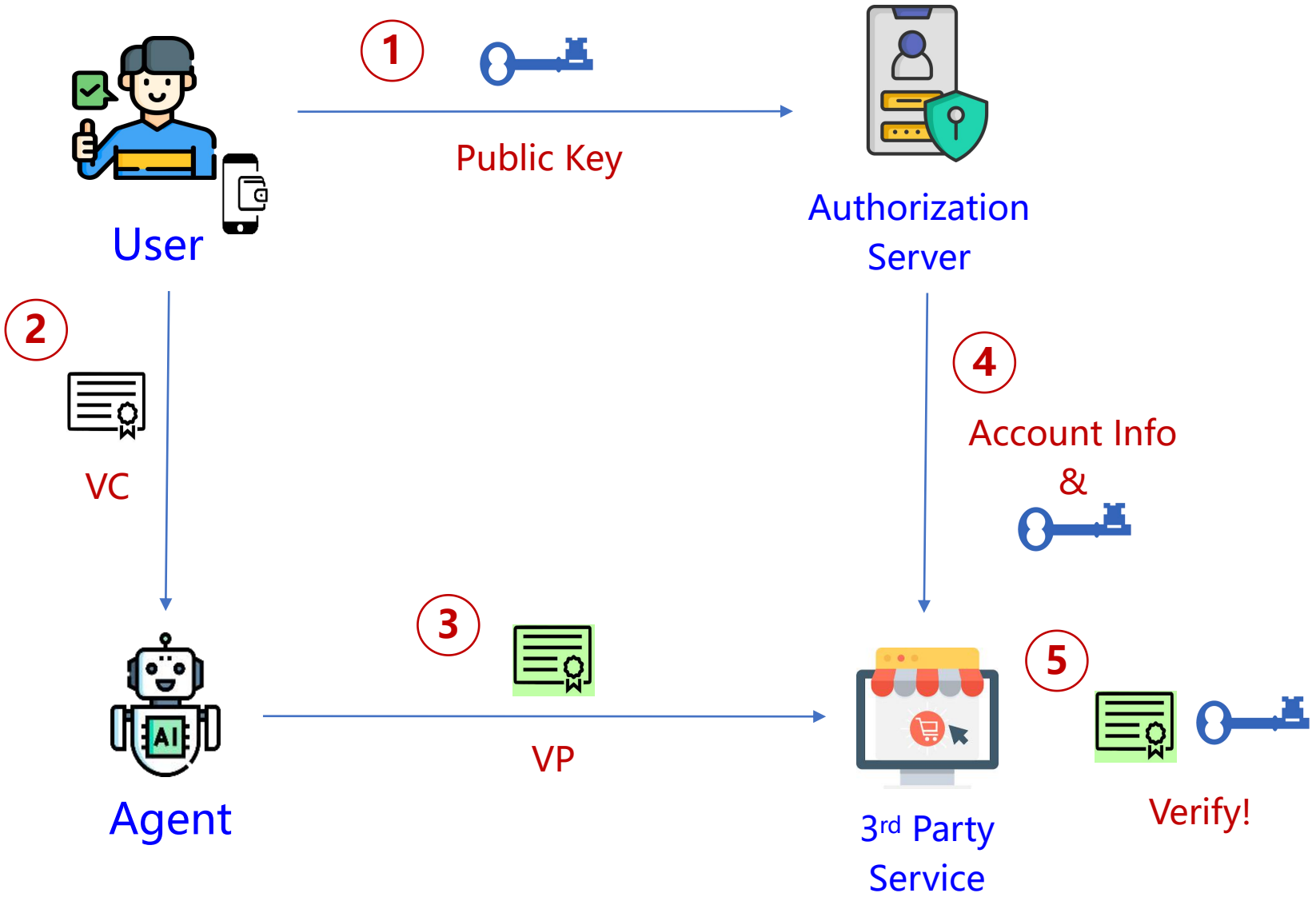
Direct AI Agent Authorization by Users

Users authorize an Agent using VCs, and the verifier performs access control based on the authorization.
How can the user identity be trusted?



Verification:
1. Has the authority to make the purchase
2. Purchase price $1,800 < x

Bridging the Trust Gap: OAuth for Key Binding, VC for Agent Delegation



Draft: OAuth 2.0 Rich Authorization Requests for AS-Attested User Certificates

- **User public key registration**: The user submits the public key to the (AS) in advance for identity binding
- **Obtain long-term credential:** The user requests a Refresh Token (RT) from the AS and provides the authorization verifiable credential (VC) to the agent
- **Issue proof token**: After verifying the RT, the AS issues an Access Token (AT)
- **Submit token**: When the agent accesses the resource server (RS), the AT and the authorization VC are submitted simultaneously
- **Permission verification**: The RS extracts the user public key using the AS certificate in the token, and then verifies whether the user signature on the VC is correct

```
+------+          (1) Register Public Key (PK)          +---------------+
|      |-------------------------------------------------->|               |
|  RO  |          (2) Acknowledge & Store PK             | Authorization |
|      |<--------------------------------------------------|  Server (AS)  |
+------+                                                  |               |
   |                                                      |               |
   |      (3) Interactive Authz Request (via Client)      |               |
   +------------------------------------------------------>|               |
   |                                                      |               |
   |      (4) Explicit Consent for Refresh Token (RT)     |               |
   |<------------------------------------------------------|               |
   |                                                      |               |
   |              (5) Issue Refresh Token (RT)            |               |
   |   +--------------------------------------------------|               |
   |   |                                                  +---------------+
   v   v
+----------+                                              +---------------+
|          |      (6) Delegate Intent (e.g., via VC)      |               |
|  Client  |<--------------------------------------------|      RO       |
| (Agent)  |          (Signed with Private Key)           |               |
+----------+                                              +---------------+


+----------+      (A) Token Request (Refresh Token + RAR)       +---------------+
|          |-------------------------------------------------------->|               |
|  Client  |                                                    | Authorization |
| (Agent)  |      (B) Access Token (includes AS-signed Cert)    |  Server (AS)  |
|          |<--------------------------------------------------------|               |
+----------+                                                    +---------------+
     |
     |    (C) API Request + AT + RO-signed VC
     v
+----------+      (D) [Optional] Introspect AT                  +---------------+
| Resource |-------------------------------------------------------->| Authorization |
| Server   |      (E) Return Certificate Data                   |  Server (AS)  |
|  (RS)    |<--------------------------------------------------------|               |
|          |                                                    +---------------+
|          |-- (F) Extract Cert & Verify AS Signature
|          |-- (G) Verify VC Signature using User PK from Cert
|          |-- (H) Execute Authorized Operation
+----------+
```

Thank you.

把数字世界带入每个人、每个家庭、
每个组织，构建万物互联的智能世界。

Bring digital to every person, home and organization for a fully connected, intelligent world.

Copyright©2018 Huawei Technologies Co., Ltd.
All Rights Reserved.

The information in this document may contain predictive statements including, without limitation, statements regarding the future financial and operating results, future product portfolio, new technology, etc. There are a number of factors that could cause actual results and developments to differ materially from those expressed or implied in the predictive statements. Therefore, such information is provided for reference purpose only and constitutes neither an offer nor an acceptance. Huawei may change the information at any time without notice.

HUAWEI